3. Privacy Threats and Auditing Foundations

This review focuses primarily on membership privacy because the strongest available evidence on unequal patient-level exposure concerns membership inference. Attribute inference, model inversion, reconstruction, and training-data extraction are considered to clarify what membership auditing does not measure and why a broader privacy assessment may require several attack-specific outcomes. Throughout this review, empirical attack performance is treated as conditional evidence under a stated threat model, not as a universal probability of harm or a substitute for a formal privacy guarantee.

3.1 Membership Inference in Clinical AI

Membership inference attacks (MIAs) seek to determine whether a particular record, or a set of records associated with one person, contributed to the data used to train a machine-learning model. The inference target is participation in training rather than the clinical outcome that the model was designed to predict. Shokri et al. demonstrated that prediction outputs can reveal patterns that distinguish training members from non-members, including for models trained on hospital-discharge data [1]. Clinical scan-level attacks on neuroimaging regression models independently show feasibility in another modality, but do not estimate multi-record patient vulnerability [49]. An attacker does not need to reconstruct the complete training set: establishing that a known record participated in training may itself disclose information that the contributor expected to remain private.

The general attack mechanism exploits differences between a model's behavior on training examples and its behavior on previously unseen examples. Training may produce distinctive patterns in confidence, loss, prediction margins, or internal representations. High confidence alone is not conclusive, however, because some observations are intrinsically easy to classify regardless of membership. Shadow-model attacks learn member and non-member behavior from auxiliary models with known membership [1]. LiRA instead compares the target model's response with example-specific reference distributions representing inclusion and exclusion, shifting the question from whether a prediction is confident to whether it is unusually consistent with training participation [2].

The clinical sensitivity of membership depends on what participation reveals. Membership in a broadly defined development cohort may disclose little beyond general eligibility, whereas membership in a narrowly defined disease, treatment, or institution-specific cohort may reveal sensitive health or care information. Knolle et al. illustrate this concern with a model developed to predict immunotherapy efficacy: participation in the relevant training cohort can imply cancer status [3]. Such implications must nevertheless be interpreted through cohort eligibility, linkage evidence, and attack uncertainty; a membership prediction is not automatically a verified clinical fact.

Clinical datasets also make record-level and patient-level membership non-equivalent. One patient may contribute several scans, visits, waveforms, or laboratory measurements. Successful inference for any linked contribution may disclose that patient's participation, while an audit of only one record may overlook exposure associated with the remaining records. Knolle et al. found that a small number of patients could be highly distinguishable even when aggregate attack performance remained close to chance [3]. Membership inference therefore provides the principal empirical lens for this review's analysis of unequal privacy exposure, but its interpretation requires an explicit patient-level unit and does not exhaust all forms of patient privacy harm.

3.2 Threat Models and Adversarial Knowledge

A threat model specifies the conditions under which privacy leakage is assessed: the adversary's objective, access to the target model, knowledge of the target input and label, auxiliary data, knowledge of the training procedure, and computational or query budget. ML-Doctor provides a useful taxonomy separating model access from auxiliary-data availability [4]. For clinical applications, the threat model must additionally identify whether the target is a record or a patient, how multiple records are linked, and what clinical fact participation could reveal. A reported vulnerability is therefore conditional on an explicit adversarial scenario rather than a context-free property of the model.

Model access should be described through the information actually exposed. Confidence-based black-box access returns prediction scores, whereas label-only access returns only the predicted class. Label-only access is not necessarily safe: Choquette-Choo et al. showed that an adversary can use the stability of predicted labels under input perturbations as a membership signal [5]. White-box access can reveal parameters, gradients, losses, or intermediate representations. ML-Doctor evaluates attacks using several such signals [4]. Access to loss does not always imply white-box access, because a correct label and the corresponding output probability may be sufficient to calculate it.

Auxiliary knowledge is a separate dimension. An attacker may know the target input, its correct label, the population distribution, parts of the training set, or enough of the learning procedure to construct reference models. ML-Doctor distinguishes independent auxiliary samples from known members of the actual training set [4]. Carlini et al. distinguish online LiRA, which uses reference models trained with and without the target, from offline variants that approximate the comparison primarily through OUT models [2]. Here, *online* describes target-dependent attack preparation rather than access during the target model's original training. Reference-data overlap, distribution mismatch, and deviations from the target training procedure should consequently be reported separately.

Clinical interpretation further depends on identity linkage and record completeness. Possession of a medical image does not necessarily imply knowledge of the patient's identity, diagnosis, or other encounters. Conversely, an attacker with several records from the same person may exploit subject-specific structure even when the exact training record is unavailable. Knolle et al. evaluate restricted auxiliary information through selected subsets of electronic-health-record variables and reduced ECG inputs [3]. These experiments demonstrate vulnerability under the tested restrictions, not under every form of missing information. Their repeated-model procedure for estimating individual vulnerability should also be distinguished from the resources required by a practical single-model attack.

3.3 Privacy Metrics and Their Interpretation

Membership inference is usually evaluated as a binary decision task in which a training member is the positive class. If TP and FN denote correctly detected and missed members, and FP and TN denote incorrectly and correctly rejected non-members, then

$$\text{TPR} = \frac{TP}{TP + FN}, \qquad \text{FPR} = \frac{FP}{FP + TN}.$$

TPR is the fraction of members detected, whereas FPR is the fraction of non-members incorrectly flagged. Both require an explicit evaluation unit. Counting records answers a different question from counting patients, and a patient-level analysis must define membership and the rule used to combine evidence across related records. Ye et al. further show that the meaning of an estimated rate depends on which elements of the membership experiment are fixed and which are resampled [6].

Attack accuracy measures the proportion of correct membership decisions at a selected threshold. It depends on the decision rule and the member prevalence in the evaluation sample, so a high value can be uninformative in an imbalanced setting. ROC-AUC summarizes ranking across all thresholds. For a membership-oriented score, it can be interpreted as the probability that a randomly selected member receives a higher score than a randomly selected non-member, with half-weight for ties. This is a population-ranking interpretation: an AUC of 0.90 does not mean that a particular patient has a 90% probability of membership.

Neither aggregate accuracy nor ROC-AUC describes how exposure is distributed across patients. Carlini et al. emphasize evaluation at low FPR because an attack may identify a small subset of members with high confidence despite modest average performance [2]. Studies should report the chosen operating point, such as 10^{-3}, together with its TPR, sample counts, and uncertainty. The number of non-members must support the claimed resolution; observing no false positives in a small sample does not establish a negligible population FPR.

Precision answers a complementary question: among examples classified as members, what proportion are truly members? If π is the membership prevalence in the candidate population, then

$$\text{Precision} = \frac{\pi\,\text{TPR}}{\pi\,\text{TPR} + (1-\pi)\,\text{FPR}}.$$

Precision from a balanced experimental audit cannot be transferred directly to a deployment population in which membership is rare. For example, with $\pi = 0.001$, TPR $= 0.5$, and FPR $= 0.001$, precision is approximately 33.4%. Even a low FPR can therefore produce many incorrect claims when non-members substantially outnumber members. A calibrated probability for an individual patient requires additional modeling and validation.

The evaluation unit and source of randomness must be stated. Knolle et al.'s patient-level maximum of record-specific AUCs is a worst-record description, not the AUC of a joint patient attack [3]. Ye et al. distinguish fixed-target and resampled membership games [6], while Kulynych et al. show that subgroup threshold procedures can overstate disparity [7]. Report target and non-member counts, repetitions, uncertainty, dependence among records and the unit at which FPR is controlled.

3.4 Empirical Privacy Auditing and Formal Privacy Guarantees

Empirical auditing asks whether specified attacks can extract information about training participation from an implemented model. Its conclusions depend on the evaluated data, threat model, model access, attack strength, and experimental protocol. A successful attack demonstrates exploitable leakage under those conditions, but its observed performance does not characterize every possible adversary. A failed attack may instead reflect unsuitable reference data, a weak statistic, distribution mismatch, or an insufficient computational budget. Stronger attacks can revise conclusions derived from weaker evaluations [2]. Auditing is therefore appropriate for detecting vulnerabilities and comparing systems under controlled conditions, but not for certifying universal privacy.

Differential privacy provides a different form of evidence. A randomized mechanism $\mathcal{M}$ satisfies (ε, δ)-differential privacy if, for every pair of neighboring datasets D, D' and measurable output event S,

$$\Pr[\mathcal{M}(D) \in S] \leq e^{\varepsilon} \Pr[\mathcal{M}(D') \in S] + \delta.$$

The adjacency relation defines the protected contribution. The parameter ε controls the multiplicative change allowed between neighboring datasets, while δ permits an additive relaxation; neither is a patient's direct probability of disclosure. DP-SGD implements this principle through contribution clipping, Gaussian noise, and privacy accounting across optimization steps [8]. Its guarantee depends on correct implementation, the sampling procedure, the accountant, and the unit used to define neighboring datasets.

The unit is especially important in clinical data. Record-level adjacency protects one record, whereas patient-level adjacency protects the complete set of records contributed by one patient. A record-level guarantee does not automatically provide the same parameters for a multi-record patient. Group-privacy reasoning can extend a guarantee across several records but generally weakens its parameters [41]. Knolle et al. report lower patient-level membership vulnerability under stronger record-level DP while emphasizing the mismatch that can arise when individuals contribute multiple records [3]. Patient-level empirical measurements should not be compared with a single-record formal bound until the protected units are aligned.

A valid DP proof concerns the declared contribution and adjacency relation; an attack audit measures exposure in an implemented system under a specified threat model. The former does not determine who has the greatest empirical vulnerability or how utility is distributed, and the latter cannot certify a formal bound [2,3,8,41].

3.5 Other Privacy Attacks Relevant to Patient-Level Assessment

Membership inference determines whether a record or patient contributed to training, but it does not measure every form of information exposure. Attribute inference, model inversion, gradient reconstruction, and training-data extraction target different secrets and require different access. ML-Doctor distinguishes these attack families and shows that they may respond differently to the same

defense [4]. Its evidence is based mainly on general image benchmarks, however, and model stealing should not be treated as patient-data disclosure unless the copied model enables a separate attack on patient information.

Attribute inference attempts to recover an unknown sensitive feature using the model and information already available about a person. Yeom et al. analyze an adversary that receives an incomplete record and attempts to infer a missing attribute, including genomic information, using model access and auxiliary distributional knowledge [10]. Raw accuracy is insufficient evidence of training-data leakage because the attribute may already be predictable from known features, outcomes, or population prevalence. Evaluation should compare the attack with a model-free or population baseline and quantify the additional information supplied by the trained model.

Model inversion partly overlaps with attribute inference but can target different outputs. Fredrikson et al. exploit confidence-returning interfaces to infer sensitive survey or genomic features and to construct facial representations associated with known identities [11]. Their face outputs were assessed by human recognizability, not by showing that a specific training photograph had been recovered. Inversion may therefore reveal characteristics associated with a person or class without reproducing a training record. Reviews should report the target and success criterion used by each experiment rather than treating inversion, attribute inference, and reconstruction as interchangeable.

Reconstruction and extraction can expose more direct content, but their access assumptions differ. Deep Leakage from Gradients reconstructs inputs and labels by matching dummy gradients to gradients observed during collaborative training, thereby requiring access to training-time gradients and a corresponding model state [9]. Carlini et al. instead use black-box language-model queries to generate candidate text and identify sequences confirmed as training data [12]. The latter demonstrates extraction of memorized content, but from a language model trained on public Internet text rather than clinical records. Both studies establish relevant mechanisms, not direct estimates of patient-level clinical exposure.

A multi-attack profile should keep membership, attribute inference, inversion, reconstruction and extraction outcomes on their native scales, with explicit patient linkage and access assumptions. A defense against one secret does not establish protection against another. Table 3.1 maps their evidentiary scope.

Table 3.1. Privacy attacks relevant to patient-level assessment

Study	Attack and target	Required access	Prior knowledge	Success measure	Link to an individual	Evidence domain
ML-Doctor [4]	Membership, attribute inference, inversion, and model stealing	Black-box or white-box, depending on attack	Shadow data, known members, or none	Accuracy, F1, AUC, MSE, or recognition	Varies by attack; stealing alone does not establish disclosure	General image benchmarks
Yeom et al. [10]	Missing sensitive attribute	Model access with an incomplete target record	Known features, outcomes, priors, and distributional information	Accuracy or advantage over a model-free baseline	Explicit target record	Mixed benchmarks, including health-related data
Fredrikson et al. [11]	Sensitive attribute or facial representation	Confidence-returning black-box interface in key experiments	Remaining attributes, outcome, and marginal priors	Accuracy, precision, recall, or human identification	Known target person, but not recovery of a specific photograph	Surveys, medical motivation, and face images

Study	Attack and target	Required access	Prior knowledge	Success measure	Link to an individual	Evidence domain
Zhu et al. [9]	Gradient reconstruction of inputs and labels	Training-time gradients and model state	Architecture, parameters, and loss	Reconstruction error and visual or token similarity	Reconstructed batch record; identity linkage is separate	General image and language data
Carlini et al. [12]	Verbatim training-text extraction	Black-box language-model queries	Prompts, public search, and candidate validation	Number and length of confirmed extracted sequences	Some sequences contain personal information; not clinical evidence	Public Internet text

3.6 Evidence Hierarchy and Limits of Transfer

Table 3.2 classifies evidence by **directness to the target claim**—membership vulnerability of an identified multi-record clinical patient—not by intrinsic study quality. A formal theorem in Tier E can be rigorous yet still lack a clinical effect estimate; a clinical DP utility study can inform Section 8 without measuring membership vulnerability. The target event, patient linkage, comparator population and protected unit must be checked within each tier.

Table 3.2. Evidence hierarchy for patient-level clinical membership claims

Tier	Evidence and representative studies	Permitted inference	Main boundary
A — Direct clinical patient-level	Patient-sampled diagnostic models with patient-linked vulnerability summaries: Knolle et al. [3]	Direct evidence of heterogeneity under the declared clinical audit	Predominantly worst-record AUC summary; one coordinated study, not independent replication
B — Clinical record or subject level	Subject-aggregated ECG with cross-dataset non-members [22]; neuroimaging scan MIA [49]; clinical-language record/group experiments, preprint [50]	Supports feasibility and modality-specific signals	Different membership games, incomplete separation of subject membership from cohort origin, or no validated multi-record patient estimand
C — Health or administrative data	Hospital discharge [1,7,19]; dependent hospital records [23]; synthetic health-data membership [53]	Demonstrates leakage or audit confounding in health-related records	Encounter or source-data membership cannot be read as diagnostic-model patient-level exposure
D — General ML empirical	LiRA, calibration, sample heterogeneity, subject-level attacks, distillation and privacy transfer [2,13,15–17,35,44]	Supports methods and plausible failure modes	Magnitude and affected patient groups do not transfer automatically to clinics

Tier	Evidence and representative studies	Permitted inference	Main boundary
E — Theoretical or mechanistic	Long-tail memorization, target dependence, influence and formal DP [27,28,33,39–41]	Motivates testable mechanisms or formal guarantees for a declared adjacency relation	Does not estimate clinical patient-level empirical vulnerability

These categories apply to particular **claims**, not whole papers: the clinical DP studies [51,52,54,55] are directly relevant to feasibility or subgroup utility, but they do not independently replicate Tier A patient-level membership findings. Subsequent sections use this hierarchy when distinguishing observation, mechanism, and proposed intervention.